Поглиблений аналіз СУМЗ

Мета та основний результат

У роботі розглянуто три загрози для системи управління медичними записами: використання чужого токена, зміну результатів аналізів і витік файлів зі сховища. Для кожної загрози визначено STRIDE-категорію, техніку MITRE ATT&CK, контролі NIST SP 800-53 Rev. 5 та спосіб їх перевірки. До запуску MVP потрібні серверна авторизація, керування сесіями, приватне сховище і захищений аудит.

Архітектурні припущення

Розглядається вебсистема клініки з кабінетами пацієнта, лікаря й лаборанта, окремою адмінпанеллю, API, сервісом ідентифікації IdP, реляційною БД та хмарним об’єктним сховищем PDF і сканів. Мобільного клієнта на етапі MVP немає. Це модель для аналізу, а не опис перевіреної реалізації.

Компонент	**Актив і довірча межа**
Вебкабінети та адмінпанель	Недовірений клієнт. Дані запиту, роль та ID пацієнта потребують перевірки на сервері.
IdP та API	IdP підтверджує особу; API перевіряє право на конкретний запис і дію. Інтернет відділений від серверної зони.
БД медичних записів	Діагнози, результати, зв’язки лікар–пацієнт. Доступ лише від дозволених служб, без прямого доступу клієнта.
Об’єктне сховище	Медичні документи. Окрема хмарна політика доступу; приватний доступ лише через backend.
Сховище аудиту	Хто, коли і що зробив. Окремі права: застосунок записує події, але не видаляє їх.

Логіка потоків даних

F1: користувач проходить автентифікацію через IdP. F2: вебклієнт передає запит до API; API перевіряє сесію та повноваження. F3: API читає або змінює БД. F4: API отримує приватний файл і передає його авторизованому користувачу. F5: IdP, API та сховище надсилають події до аудиту. Усі мережеві потоки захищено TLS; БД і сховище не довіряють клієнтському інтерфейсу.

1 Використання викраденого токена

Загроза та сценарій

Зловмисник отримує чинний access token лікаря, наприклад із помилково збереженого діагностичного журналу, і надсилає запити до API від його імені. Передумови: токен потрапив за межі довіреної зони та ще не відкликаний. API приймає bearer token як доказ доступу й повертає записи, доступні лікарю. Викрадення токена є передумовою; тут аналізується його подальше використання.

STRIDE: S - Spoofing; можливий наслідок I - Information Disclosure. Для API важливо правильно пов’язати запит з особою: інакше чужа сесія відкриває історії хвороб, а журнал може помилково приписати дії лікарю.

Відповідність MITRE ATT&CK

T1550.001 - Use Alternate Authentication Material: Application Access Token. Техніка описує використання викрадених токенів для доступу без звичайного входу. Вона відповідає повторному використанню чинного токена, а не криптографічному створенню підробленого JWT. Таке розмежування точніше, ніж автоматично відносити будь-яку атаку на токени до T1078 Valid Accounts. [1]

Контролі та реалізація в СУМЗ

IA-5 - Authenticator Management. На рівні IdP і backend керувати видачею, строком дії та відкликанням токенів. Проєктний параметр: access token до 10 хвилин, ротація refresh token при використанні та блокування сімейства refresh token при повторному використанні. Токени й секрети не записувати в логи; ключі тримати в менеджері секретів. Це скорочує вікно використання викрадених даних. [4]

SC-23 - Session Authenticity; SC-23(1) - Invalidate Session Identifiers at Logout. API перевіряє підпис, дозволений алгоритм, issuer, audience та строк дії. Для MVP застосувати серверний реєстр сесій: вихід і примусове відкликання роблять сесію недійсною на кожному наступному запиті. Саме перевірка стану сесії, а не лише підпис JWT, дає негайне припинення доступу. [4]

AC-3 - Access Enforcement. Backend при кожному читанні перевіряє роль, клініку та зв’язок лікаря з пацієнтом. Це обмежує обсяг витоку навіть за наявності справжнього токена. IA-2 - Identification and Authentication (Organizational Users), з IA-2(1) та IA-2(2), забезпечує MFA для привілейованих і звичайних облікових записів персоналу. MFA знижує ризик захоплення облікового запису, але не зупиняє повторне використання вже викраденого bearer token. [4]

MVP і перевірка

Реально для MVP: готовий IdP з MFA, серверне відкликання, перевірка токенів і об’єктна авторизація. Складність середня; криптографічне прив’язування токена до клієнта можна додати пізніше. Критерії: токен після logout або відкликання дає 401; чинна сесія без права на пацієнта - 403/404; прострочений токен і токен з чужим audience - 401. Залишається ризик дій у межах викраденої активної сесії до її виявлення.

2 Підміна результатів аналізів

Загроза та сценарій

Користувач із чинним обліковим записом пацієнта змінює ідентифікатор результату в запиті на редагування. Через відсутність серверної перевірки прав API приймає нове значення та перезаписує чужий результат у БД. Передумова - помилка авторизації на рівні об’єкта або функції; прихована кнопка в інтерфейсі її не усуває.

STRIDE: T - Tampering; додатково E - Elevation of Privilege, оскільки пацієнт виконує функцію лаборанта. Цілісність результатів критична: лікар може прийняти неправильне рішення на підставі змінених даних. Це загроза для backend і БД, навіть якщо транспорт зашифрований.

Відповідність MITRE ATT&CK

T1565.001 - Data Manipulation: Stored Data Manipulation. Зловмисник змінює збережені дані, щоб вплинути на подальші рішення чи процеси. Тут це підміна результату, який лікар згодом прочитає з БД. Техніка описує маніпуляцію даними, але не саму вразливість авторизації; остання є способом отримати можливість запису. [2]

Контролі та реалізація в СУМЗ

AC-3 - Access Enforcement. У backend дозволяти зміну лише лабораторній ролі в межах конкретної клініки та призначеного дослідження. Пацієнт має право читати власний результат, але не редагувати його. Завершений результат виправляти створенням нової версії із зазначенням причини, автора і часу. Це блокує сценарій до запису в БД. [4]

AC-6 - Least Privilege. БД і лабораторна служба використовують окремі облікові записи з мінімальними правами. Звичайний backend не працює як власник БД; адміністратор користувачів не отримує автоматично право змінювати клінічні дані. Розділення прав зменшує наслідки компрометації, але не замінює перевірку пацієнта в API. [4]

AU-12 - Audit Record Generation та AU-9 - Protection of Audit Information. Backend фіксує кожну спробу зміни: користувача, роль, об’єкт, час, результат, причину і посилання на версії запису. Події надсилаються в окреме сховище; застосунок не має права змінювати чи видаляти журнал. Оповіщення про спробу його зміни надходить відповідальному. Повні медичні значення не дублюються у загальному технічному лозі. Аудит дає змогу виявити підміну та відновити послідовність подій. [4]

MVP і перевірка

Авторизація, мінімальні права, історія версій та базовий захищений аудит потрібні до запуску. Складність середня: найбільше часу потребує матриця прав і узгоджена модель виправлень. Перевірка: пацієнт не змінює навіть власний результат; лаборант іншої клініки отримує відмову; дозволене виправлення створює нову версію; спроба видалити аудит від імені застосунку блокується. Залишається ризик неправдивого результату від уповноваженого працівника; для критичних виправлень потрібне незалежне погодження.

3 Витік файлів із хмарного сховища

Загроза та сценарій

Через помилкову політику доступу контейнер із PDF-виписками стає публічним. Зловмисник отримує адресу об’єкта з пересланого посилання і завантажує документ без входу до СУМЗ; за наявності дозволу на перелік об’єктів збирає інші файли. Передумова - дозволений анонімний доступ до читання. Навіть без переліку об’єктів відомий URL може відкрити конкретну виписку.

STRIDE: I - Information Disclosure. Об’єктне сховище містить чутливі медичні дані, а прямий доступ до нього може обійти всі перевірки вебзастосунку. Тому політика доступу самого сховища є окремою довірчою межею.

Відповідність MITRE ATT&CK

T1530 - Data from Cloud Storage. Техніка описує збір даних із хмарних сховищ, зокрема через помилково наданий публічний доступ. Відповідність залежить від припущення про хмарне об’єктне сховище. Для звичайного публічного URL на локальному вебсервері це зіставлення потребувало б перегляду. T1530 описує збір, а не всі можливі подальші способи виведення даних. [3]

Контролі та реалізація в СУМЗ

AC-3 - Access Enforcement. У сховищі заборонити анонімне читання і перелік об’єктів; дозволити доступ лише службовій ідентичності backend. У MVP файли передаються через API після перевірки права на конкретний документ. Непередбачуване ім’я файла не є заміною авторизації. Таке рішення перекриває прямий публічний шлях доступу. [4]

CM-6 - Configuration Settings. Зафіксувати приватну конфігурацію як еталон, обмежити право її змінювати та перевіряти відхилення. Перед релізом автоматична перевірка повинна відхиляти конфігурацію з публічним доступом. Після розгортання перевірка стану й повідомлення про зміну політики допомагають виявити повторне відкриття сховища. [4]

AU-12 - Audit Record Generation та AU-6 - Audit Record Review, Analysis, and Reporting. Увімкнути події читання об’єктів і зміни політик, а не лише адміністративний журнал. Backend фіксує користувача та ID документа для зіставлення з читанням службовою ідентичністю. Відповідальний переглядає масові завантаження та невдалі спроби доступу. Оповіщення допомагають швидко закрити доступ і визначити обсяг інциденту. [4]

SC-28 - Protection of Information at Rest. Шифрування об’єктів і резервних копій з окремим керуванням ключами зменшує ризик доступу до носіїв. Воно не усуває публічне читання: якщо політика дозволяє GET, сервіс може повернути вже розшифрований файл. Тому це додатковий, а не основний контроль для цього сценарію. [4]

MVP і перевірка

Приватний доступ та шифрування керованого сховища зазвичай мають низьку або середню складність і потрібні вже в MVP. Перевірка: відомий URL без автентифікації не повертає файл; пацієнт А не отримує документ Б через API; публічна політика блокується перевіркою розгортання; тестове масове читання породжує оповіщення. Залишається ризик копіювання документів законним отримувачем.

4 Пріоритети та залишковий ризик

Пріоритети визначено якісно, без статистики реальних інцидентів. Підміна результатів має найвищий пріоритет через можливий вплив на лікування. Захоплення сесії та відкриття сховища також мають високий пріоритет через потенційно масове розголошення даних.

Етап	Що впроваджувати	Ресурси
До MVP	AC-3, AC-6: матриця прав у backend та обмежені ролі БД; негативні тести доступу.	Середні: розробник і власник клінічних процесів.
До MVP	IA-5, SC-23, IA-2(1)/(2): готовий IdP, MFA персоналу, керування сесіями.	Середні: інтеграція, підтримка відновлення доступу.
До MVP	CM-6, AC-3, SC-28: приватне сховище, TLS, шифрування БД і копій.	Низькі–середні для керованих сервісів.
До MVP	AU-12, AU-9, AU-6: окремий журнал, базові оповіщення, призначений відповідальний.	Середні: інтеграція та постійний перегляд.
До MVP	CP-9 System Backup: резервні копії та пробне відновлення БД і файлів.	Середні: місце, графік, перевірка відновлення.
Після MVP	Розвинена кореляція SIEM, поведінкова аналітика, прив’язування токенів до клієнта.	Високі: ліцензії, налаштування, аналітики.

Допустимі компроміси

Можна почати з готового IdP, керованого шифрування та простих правил оповіщення замість власної системи автентифікації й дорогого SIEM. Перегляд журналів може виконувати призначений працівник за графіком із негайними повідомленнями про критичні події. Не можна відкладати серверну авторизацію, приватність сховища або повністю відмовлятися від аудиту. MVP означає менше функцій, а не використання реальних медичних даних без базового захисту.

Обмеження та висновок

Три сценарії не покривають DDoS, ransomware, SQL-ін’єкції, XSS, компрометацію пристроїв і всі інсайдерські зловживання. Резервні копії зменшують наслідки втрати даних, але не запобігають витоку. Потрібні окремі перевірки вразливостей, план реагування та оцінка доступності.

Ключове рішення - розмістити перевірки біля активу: авторизацію в API, обмеження запису в БД, приватність у сховищі та захист журналів в окремому контурі. Прийнятність залишкового ризику має підтверджувати власник системи після перевірки критеріїв, а не лише після ввімкнення налаштувань.

5 Передавання лабораторного модуля вендору
Додатковий сценарій: зовнішня лабораторія надсилає результати до СУМЗ через інтеграційний API. З'являється нова довірча межа між середовищем вендора та backend клініки. Справжність з'єднання ще не доводить правильність медичного результату.

Як змінюються загрози
Для загрози 1 небезпечним стає викрадення службового токена вендора: автоматична інтеграція може працювати без інтерактивного MFA. Для загрози 2 зростає ризик підміни номера замовлення, повторного надсилання старого результату або запису до іншої клініки. Для загрози 3 з'являються додаткові копії документів і журналів у сторонній організації.

Додаткові та посилені контролі
SA-9 - External System Services. До інтеграції визначити вимоги до захисту сервісу, відповідальність сторін, порядок повідомлення про інцидент, допустимі дані й спосіб контролю виконання. Клініка має регулярно перевіряти погоджені докази захисту вендора. Власник - керівник системи та відповідальний за постачальника. [4]

CA-3 - Information Exchange. Описати обмін: склад даних, напрямок, протокол, ідентифікатори клініки та дослідження, правила зберігання і припинення доступу. Передавати лише дані, необхідні для виконання лабораторного замовлення. Власник - архітектор разом із представником лабораторії. [4]

IA-9 - Service Identification and Authentication; посилення AC-3 та AC-6. Інтеграційний шлюз перевіряє окрему службову ідентичність вендора, наприклад через mTLS та короткоживучий токен. Дозволено лише передавання результатів за призначеними замовленнями; масове читання історій хвороб заборонено. Ключі інтеграції ізольовано від користувацьких сесій. [4]

SI-10 - Information Input Validation. Backend перевіряє схему, типи, одиниці вимірювання, зв'язок із замовленням і допустимість переходу статусу. Унікальний ID події та контроль версії запобігають повторній обробці повідомлення. Невідповідні дані потрапляють на перевірку, а не перезаписують підтверджений результат. Це не доводить клінічну достовірність даних від скомпрометованого вендора. [4]

План упровадження і перевірки
До запуску інтеграції потрібні окремі ключі, мінімальні права, валідація повідомлень, аудит та процедура аварійного вимкнення. Перевірити: повідомлення від невідомого сервісу відхиляється; результат для чужої клініки не зберігається; повторне повідомлення не створює повторної зміни; відкликання інтеграції блокує наступний запит. Більш ресурсомісткі заходи - незалежний аудит постачальника та постійний моніторинг його ризиків.

При недоступності вендора СУМЗ зберігає останній підтверджений результат і явно показує відсутність нового. Дані не підмінюються автоматично. Процедуру ручного передавання й подальшого звіряння результатів погоджують із клінікою заздалегідь.

6 Методика зіставлення та джерела

Як використано стандарти

STRIDE визначає тип порушення властивостей системи. ATT&CK описує поведінку зловмисника. NIST SP 800-53 Rev. 5 надає каталог контролів. Між ними немає автоматичної відповідності один до одного: одну техніку стримують кілька контролів на різних рівнях.

Зіставлення контролів у цій роботі є аналітичним добором для конкретної архітектури, а не твердженням про дослівні зв’язки в CTID Mappings Explorer. CTID використано як довідковий ресурс методики; назви технік перевірено на MITRE ATT&CK, назви контролів - за каталогом NIST. Числові параметри сесій і критерії тестів є проєктними рішеннями для СУМЗ, а не універсальними вимогами NIST.

Загроза	**STRIDE**	**ATT&CK**	**Основні контролі**
Чужий токен	S; наслідок I	T1550.001	IA-5, SC-23, AC-3
Підміна результату	T; додатково E	T1565.001	AC-3, AC-6, AU-12, AU-9
Відкрите сховище	I	T1530	AC-3, CM-6, AU-12, AU-6